DPIA Case Study: Crave Hub AI Voice Ordering and Personalized Recommendations

An illustrative Data Protection Impact Assessment, aligned to GDPR and India's DPDP Act 2023 (with the DPDP Rules 2025), for a hypothetical new feature at a product-based consumer company. It is built only from publicly visible product behavior.

1. Document Control and Threshold Assessment

A DPIA is required: the feature combines AI, voice capture, precise location and large-scale profiling of millions of people.

Field	Entry
DPIA reference	DPIA-2026-002
Processing activity	Voice-based ordering plus AI-personalized restaurant and grocery recommendations, with live order and rider tracking
Organization (Data Fiduciary / controller)	Food and quick-commerce delivery platform
Assessment owner	Privacy Analyst
Business owner	Head of Consumer Product
DPO / Privacy Lead consulted	DPO
Version / status	Draft v0.1
Frameworks	DPDP Act 2023, DPDP Rules 2025, GDPR (for any EU-resident users)

Terminology.

GDPR controller = DPDP Data Fiduciary.

Data subject = Data Principal.

Supervisory authority = Data Protection Board of India.

Trigger	Applies?	Reasoning
GDPR Art. 35 high-risk processing	Yes	New technology (voice AI) plus systematic profiling at scale
Special category inference	Yes	Orders can reveal religion (halal, Jain, fasting meals), health (diabetic, low-sodium) and lifestyle
DPDP s.10 Significant Data Fiduciary	Likely	Because the app handles a large amount of personal and sensitive data, the government may classify it as a Significant Data Fiduciary (SDF). If classified, it must conduct regular DPIAs and audits.
Precise location tracking	Yes	Home address and live GPS
Children's data	Possible	Minors may order through family accounts or use the app directly
Change to existing processing	Yes	Adds voice capture and a new recommendation model to existing order data

Two groups of Data Principals are affected: **customers**, and **delivery partners (riders)**, whose live location and performance data are also processed.

2. Description of the Processing

Users speak an order or a query; the app transcribes it, ranks restaurants and items using order history, and shows live tracking until delivery.

Purposes:

P1 fulfills the order.

P2 voice ordering.

P3 personalized recommendations and offers.

P4 fraud and safety checks.

P5 service analytics.

Data category	Examples	Data Principal	Required?
Identity and contact	Name, phone, email	Customers, riders	Yes
Precise location	Delivery address, live GPS	Customers, riders	Yes (during an order)
Order history	Items, restaurants, times, spend	Customers	Yes for P1; optional for P3
Inferred attributes	Veg or non-veg, cuisine, price band, possible dietary or religious practice	Customers	No
Voice data	Audio clip and transcript	Customers	Only if voice ordering is used
Payment	Tokenized card or UPI reference (full details held by the payment provider)	Customers	Yes
Device and usage	Device ID, IP, app events	Customers, riders	Yes
Performance data	Delivery times, ratings, route traces	Riders	Yes
Children's data	Not intended; app is for adults		No

Lifecycle:

The app collects your voice, location, and order details. The API gateway securely directs this data to the appropriate services. The speech-to-text service converts voice into text, AI recommends food, and order details are shared with restaurant and delivery systems. Data is stored for analysis and deleted according to the retention policy.

Stage	Description	Who has access
Collection	Just-in-time notices for microphone and location permission; separate consent for personalization	User, app

Stage	Description	Who has access
Use	Voice transcribed; transcript and history feed recommendations	Automated systems; limited engineering
Storage	Audio kept only until transcription is verified; transcripts and order history retained per schedule	Role-based access, logged
Sharing	Restaurants and riders see only what an order needs; cloud and speech vendors act as processors; payment provider is a separate fiduciary or processor	Vendors under contract
Retention	Audio: delete within 24 hours unless the user opts in to save. Order history: account life, then as required by tax and accounting law. Rider route traces: 90 days.	Automated jobs

3. Necessity Assessment

Order fulfilment is clearly necessary; voice capture and inferred-attribute profiling are the parts that need the strongest justification.

Purpose	Ground under DPDP	Notes
P1 Fulfil order	Consent (s.6)	Address and payment details are provided voluntarily for the order. Some processing may also qualify under legitimate uses (s.7) such as legal obligation.
P2 Voice ordering	Consent (s.6)	Microphone use is optional and the typed flow must remain available
P3 Personalization	Consent (s.6) and withdrawable	Off by default. Inferring religion or health from meal choices is avoided.
P4 Fraud and safety	Consent or legitimate use, to be confirmed by Legal	Must be limited to what is needed to detect abuse
P5 Analytics	Consent (s.6)	De-identified data only

GDPR note: For EU-resident users, inferred religion or health data would need an Art. 9 condition. The safer design is to not create those inferences.

Consent Compliance Checklist - DPDP Act & Rules

- **Consent Validity:** Consent is free, specific, informed, unconditional, and unambiguous, with clear affirmative action.

- **Purpose Limitation & Data Minimization:** Consent is limited to personal data necessary for each specific purpose. Personalization consent is unbundled from the core ordering process.
- **Notice & Transparency:** An itemized notice is provided in clear and plain language, including information on consent withdrawal and the grievance/complaint mechanism.
- **Withdrawal of Consent:** Users can withdraw consent through a simple one-toggle option in the application settings, making withdrawal as easy as providing consent.
- **Consent Manager Integration: Open item** — Consent Manager integration is yet to be implemented. The implementation roadmap needs to be confirmed.
- **Parental Consent for Minors: Risk / Gap** — As the application is intended for users aged 18+, a parental-consent workflow has not been implemented. The effectiveness of the age-gating mechanism remains a compliance risk, recorded as **R04**.

Checklist

Principle	Question	Assessment	Met?
Purpose limitation	Are purposes specific, and is reuse compatible?	Order data cannot be reused to train general AI models or sold for ads without new consent	Yes
Necessity	Could the aim be met with less data?	Live GPS needed only while an order is active. Contacts, photos and background location were rejected.	Yes
Data minimization	Is each element limited to what is needed?	Rider route traces are retained longer than the delivery needs	Partly
Accuracy	Is data correct where decisions rely on it?	Recommendations can mislabel preferences. Users can edit or reset their taste profile.	Yes
Storage limitation	Are retention periods defined and enforced? Is the erasure notice process in place (Rule 8)?	Schedule defined; automated deletion and 48-hour erasure notice still to be built	Partly
Integrity and confidentiality	Are reasonable security safeguards in place?	Encryption and access controls planned; voice pipeline not yet penetration-tested	Partly
Transparency	Do notices cover purpose, recipients, rights and contact?	Needs a voice-specific notice and regional-language versions	Partly
Accountability	Is it in the processing record?	RoPA entry pending	Partly

Principle	Question	Assessment	Met?
Proportionality	Is the intrusion proportionate to the benefit?	Yes for ordering. Marginal for deep profiling, which needs the opt-in design above.	Partly

4. Gap Assessment

RISK	GAP	ACTION	EVIDENCE OBSERVED
R01- Data Breach	Encryption, MFA, access controls, and masking need testing.	Implement security controls and conduct penetration testing.	VAPT Report
R02- Voice Recordings	24 Hours Voice recordings	Disable always-on recording and automate deletion.	Logs & Microphone testing
R03- Sensitive Profiling	No evidence yet that sensitive inferences are excluded from the AI model.	Remove religion and health indicators from model features and review recommendations.	Audit & fairness review
R04- Children's Data	Appropriate child-data safeguards are unresolved.	Validate age checks and obtain Legal/DPO approval before launch.	Age-gating test results and documented approval.
R05- Rider Tracking	Location restrictions and access logging need verification.	Limit location visibility to active orders and justify the 90-day retention period.	Retention Policy, Access Logs
R06- Consent	Separate, freely given personalization consent is not yet demonstrated.	Provide equally prominent accept and decline options and preserve typed ordering.	Consent-flow usability test.
R07- Vendor Misuse	Vendor restrictions and audit rights need documentary confirmation.	Execute appropriate agreements and review vendor compliance.	Vendor Register, Vendor Contracts/ Agreements
R08- Deletion Requests	Erasure or withdrawal requests not honored across all systems within the required time.	Implement and test deletion workflows and applicable notifications.	Logs, SLA reports

R09-Excessive Access	Merchants & Riders see excessive customer data	Restrict each party to the minimum information needed.	Approved data-access matrix
R010-Inadequate Notices	Voice-specific and regional-language notices are pending.	Publish clear layered notices and test comprehension.	Approved notices and comprehension-test results.

4. Risk Identification and Assessment

Ten risks were scored; six are High before controls, driven by voice data, profiling and minors.

Scoring:

Likelihood (L) and Severity (S) are each 1-5

Inherent risk = L x S

Bands:

Low 1-4, Medium 5-9, High 10-16, Very High 17-25.

ID	Risk	Affected group	L	S	Score	Rating	Legal provision
R01	Breach exposes addresses, phone numbers and order history, enabling stalking or fraud	Customers	4	4	16	High	DPDP s.8(5); GDPR Art. 32
R02	Voice recordings captured unintentionally or kept longer than needed	Customers	3	4	12	High	DPDP s.8(7); GDPR Art. 5(1)(e)
R03	Meal choices inferred as religion or health status and used for targeting	Customers	3	4	12	High	DPDP s.6; GDPR Art. 9
R04	Minors use the app or family accounts without verifiable parental consent	Children	3	4	12	High	DPDP s.9; Rules 10-11

ID	Risk	Affected group	L	S	Score	Rating	Legal provision
R05	Rider live location or trip history misused or exposed	Riders	3	4	12	High	DPDP s.8(5)
R06	Dark patterns or bundled consent make personalisation effectively mandatory	Customers	4	3	12	High	DPDP s.6
R07	Vendors (speech, cloud, analytics) reuse data for their own purposes	Customers, riders	3	3	9	Medium	DPDP s.8(2); GDPR Art. 28
R08	Erasure or withdrawal requests not honored across all systems within the required time	Customers	3	3	9	Medium	DPDP s.8(7), s.12; Rule 8
R09	Merchants and riders see more customer data than a delivery needs	Customers	3	3	9	Medium	DPDP s.8(3)
R10	Notices too long or only in English, so consent is not informed	Customers	4	2	8	Medium	DPDP s.5; Rule 3

Risk categories considered: unauthorized access, data loss, discrimination, loss of confidentiality, excessive surveillance, loss of autonomy, inability to exercise rights, incorrect decisions, financial harm, physical safety harm (location exposure), harm to children, excessive retention, function creep, inadequate transparency, cross-border transfer, re-identification.

5. Mitigation, Breach Readiness and Sign-Off

With the controls below, all ten risks are expected to fall to Low or Medium; R04 (minors) needs a DPO decision before launch.

Risk	Control	Type	Owner	Evidence / KPI	Residual accepted?
R01	Encrypt data at rest and in transit; mask phone	Technical	Eng Team	Pen-test report; no	Yes (Medium)

Risk	Control	Type	Owner	Evidence / KPI	Residual accepted?
	numbers between customer and rider; MFA and role-based access; annual penetration test			critical finding open over 30 days	
R02	Push-to-talk only (no always-on mic); delete audio within 24 hours; opt-in to save	Technical	Product	Deletion job logs	Yes (Low)
R03	Do not infer religion or health; strip such signals from the model features; fairness review of recommendations	Technical / organizational	Data Science	Feature audit	Yes (Low)
R04	18+ terms; age-estimation checks; block and delete suspected-minor accounts; no personalized offers on family accounts flagged as shared	Technical / organizational	Product, Legal	Suspected-minor accounts per month	Pending DPO decision
R05	Rider location visible only during an active order; 90-day retention; access logging	Technical	Engineering	Access-log review	Yes (Low)
R06	Unbundled consent; equal-prominence accept and decline; typed ordering always available	Design	Product	Consent-flow usability test	Yes (Low)
R07	Processor agreements barring secondary use; audit rights; vendor register	Legal	Legal Counsel	Signed DPAs; annual audit	Yes (Low)
R08	Central deletion orchestration across all stores, with the 48-hour erasure notice per Rule 8	Technical	Privacy Lead	Deletion SLA met	Yes (Low)

Risk	Control	Type	Owner	Evidence / KPI	Residual accepted?
R09	Merchants see item list and first name only; riders see address and masked phone only	Technical	Engineering	Data-access matrix	Yes (Low)
R10	Layered notice in English and major Indian languages; comprehension test	Organizatio nal	Privacy Lead	Test pass rate above 85%	Yes (Low)

Breach readiness

Requirement	GDPR	DPDP	Ready?
Notify the regulator	Within 72 hours where risk exists (Art. 33)	Detailed report to the Board within 72 hours (Rule 7)	**Partially Ready** - The reporting template, escalation procedure, and backup reporting owner are not defined.
Notify affected individuals	Without undue delay where high risk (Art. 34)	Without delay in every breach (Rule 7)	**Not Ready-** Inadequate Notices
Internal breach record	Art. 33(5)	s.8(6)	**Ready-** The Privacy Lead maintains an internal breach register containing the incident date, affected data, impact, investigation, containment actions, notification decisions, and corrective actions. The Security Team provides investigation evidence.

Records to update: processing record (RoPA), privacy notice, consent log, vendor contracts, retention schedule, incident response plan, and the grievance redressal contact (Rule 9).

Sign-off

Field	Entry
DPO advice	Processing may proceed subject to conditions: close R01-R10 actions and decide R04 before launch
DPO name and date	Harsha, 12 October 2026
Senior management approval	Mayank, 12 October 2026

"I confirm that this DPIA accurately describes the assessed processing activity to the best of my knowledge, that the identified privacy risks and proposed mitigation measures have been reviewed, and that outstanding risk and conditions have been documented."